CLOUD E IA · DEVSECOPS

DevSecOps AI Triage

Implantação de uma aplicação com Inteligência Artificial, controlada por pipeline DevSecOps, com conformidade e análise de vulnerabilidades.

Victor Marcolongo Pereira · FIAP
Disciplina de Cloud e IA · Prof. Eduardo Popovici

IA acelera, o pipeline mantém o controle

01

Aplicação com IA

API Flask que recebe um relato de incidente e sugere severidade, categoria e ações. A decisão final é humana.

02

Controle DevSecOps

Pipeline no GitHub Actions com 8 estágios: testes, segredos, SAST, SCA, Docker, imagem, DAST e deploy.

03

Conformidade

Mapeamento para OWASP, NIST SSDF, LGPD e ISO 27001, com acervo de prompts versionado no GitHub.

Arquitetura: um controle em cada fronteira

- Entrada validada por tipo e tamanho
- Prompt injection bloqueado antes do modelo
- PII redigida antes de sair (LGPD)
- Saída do modelo validada, nunca confiada
- Container não-root, somente leitura

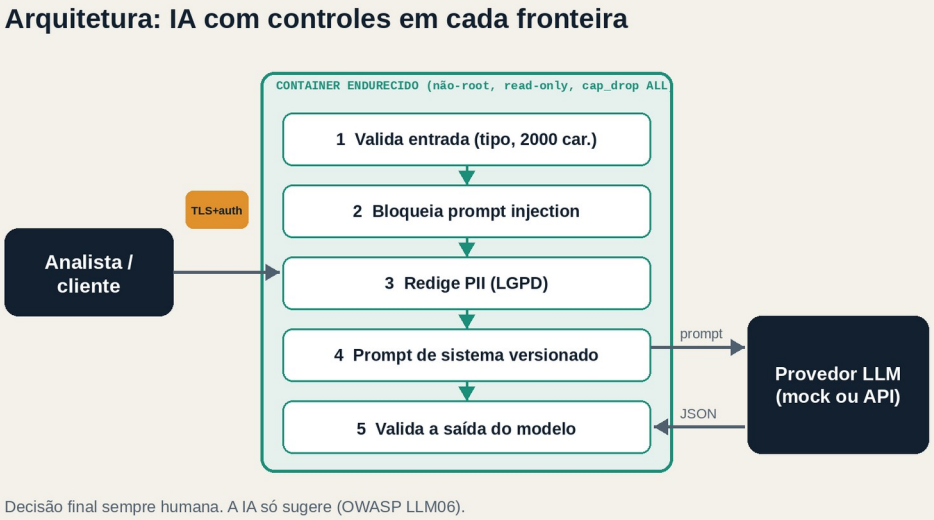
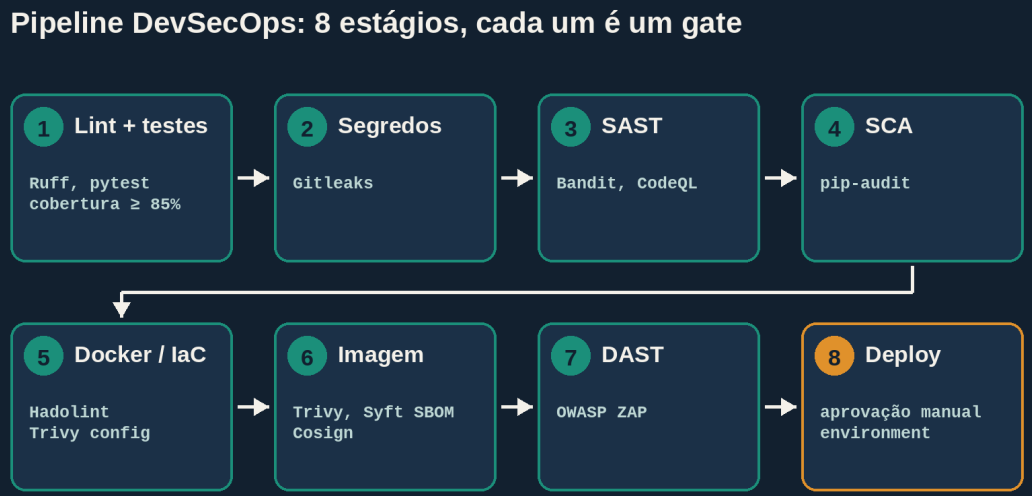


Imagem: docs/img/arquitetura.png (repositório)

Pipeline DevSecOps: cada estágio é um gate

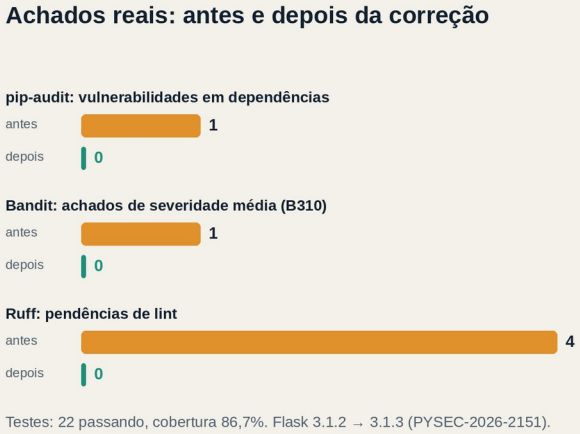


Qualquer falha bloqueia o merge e o push da imagem.

- Falha em qualquer estágio bloqueia o merge
- A imagem só é publicada depois de todos os gates
- Deploy exige aprovação manual
- Dependabot e scan semanal pegam CVEs novas

Arquivo: .github/workflows/devsecops.yml · Imagem: docs/img/pipeline.png

Vulnerabilidades com evidência real



Flask 3.1.2 → 3.1.3

pip-audit: PYSEC-2026-2151. Corrigido.

Bandit B310 (média)

URL do LLM só aceita http e https. Mitigado.

Cabeçalho Server

Gunicorn não revela mais a tecnologia.

Evidências em docs/evidencias/. Gitleaks, CodeQL, Trivy e ZAP rodam no GitHub Actions e ainda não foram executados localmente.

Conformidade em cinco referências

Referência	Controle no projeto
OWASP Top 10	Cabeçalhos de segurança, SCA, SBOM, SSRF
OWASP LLM Top 10	Anti prompt injection, saída validada, rate limit
NIST SSDF	Gates no pipeline, revisão, scan semanal
LGPD	Redação de PII, logs sem conteúdo, decisão humana
ISO 27001	A.8.8 vulnerabilidades, A.8.25 SDLC, A.8.28 código

Alinhamento de projeto acadêmico, não certificação. Detalhes em docs/CONFORMIDADE.md.

Acervo de prompts versionado no GitHub

```
prompts/
|-- README.md
|-- TEMPLATE.md
|-- REGISTRO.md
|-- sdlc/
|   |-- 01-requisitos-e-ameacas.md
|   |-- 02-codigo-e-testes.md
|   |-- 03-pipeline-e-docker.md
|   |-- 04-vulnerabilidades.md
|   |-- 05-conformidade.md
|   `-- 06-documentacao.md
`-- runtime/triage_system.md
```

- Prompt é código: ID, versão e revisão em Pull Request
- Sem segredos nem dados pessoais nos prompts
- Saída da IA é rascunho e passa por revisão humana
- O prompt de runtime é carregado pela aplicação
- REGISTRO.md guarda o que foi aceito ou descartado

Resultados e próximos passos

22
testes passando

86,7%
de cobertura

0
vulnerabilidades nas dependências

8
estágios no pipeline

Próximos passos

- Publicar no GitHub, rodar o pipeline completo e anexar os prints
- Proteger a branch main e ativar secret scanning
- Trocar o provedor mock por um LLM real via secrets

Referências e URLs

OWASP Top 10
owasp.org/Top10/

OWASP Top 10 para LLMs
genai.owasp.org/llm-top-10/

NIST SSDF
csrc.nist.gov/projects/ssdf

LGPD (Lei 13.709/2018)
planalto.gov.br/.../l13709.htm

Trivy (scan de imagem)
trivy.dev/

OWASP ZAP (DAST)
www.zaproxy.org/

Bandit (SAST Python)
bandit.readthedocs.io/

GitHub Actions
docs.github.com/actions

Imagens dos slides 3, 4 e 5: criação própria, em docs/img/ no repositório (scripts/gerar_diagramas.py). Confira cada link na fonte oficial antes de entregar.